Introduction to Snyk

Problem Statement:

We need to check for vulnerabilities and improve security while working on the Excalidraw codebase

This lets us review the layouts and user flows, gather feedback, and resolve usability issues before development begins.

Tool spec

Tool Snyk (https://snyk.io)

CLI 1.1308.4

Plan FREE PLAN

Everything in this guide works on Snyk's Free plan; no payment needed.

01 Open a Terminal

Start by simply opening a terminal and running 'npm install -g snyk'. you can run 'snyk --version' to check it installed properly.

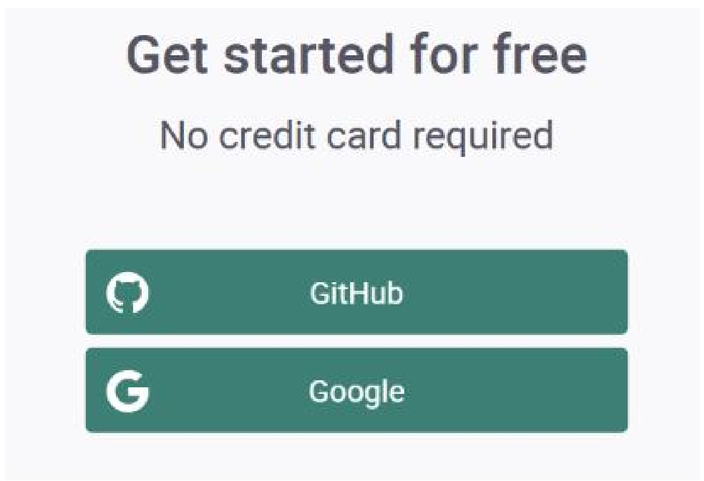
```
PS C:\excalidraw> npm install -g snyk

added 10 packages in 26s

8 packages are looking for funding
  run `npm fund` for details
```

02 Create an Account

Run 'snyk auth' to open a page in an external window where you can create an account using your GitHub account or simply an email.



Cost and plan limits

Free: $0 (what we use). Unlimited developers; monthly tests capped at Open Source 200, Code 100, IaC 300, Container 100.

Team: $25 / dev / month (5–10 devs). Ignite: $1,260 / dev / year. Enterprise: custom quote.

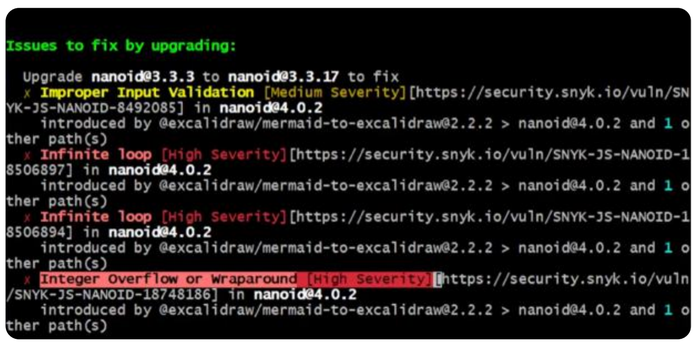
Caveat: the Free plan leaves out paid features such as higher test limits, Jira integration, license-compliance checks, reporting and SSO.

Using Snyk

01 In the Terminal

When trying to test from the Terminal, we can run the following commands to scan different portions of the codebase. --all-projects is needed because Excalidraw is a monorepo with several package.json files.

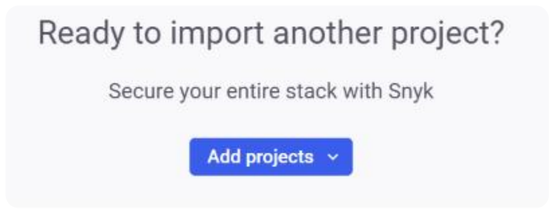
```
# scan dependencies
snyk test --all-projects
# scan our own source code
snyk code test
# upload results to the web dashboard
snyk monitor --all-projects
```



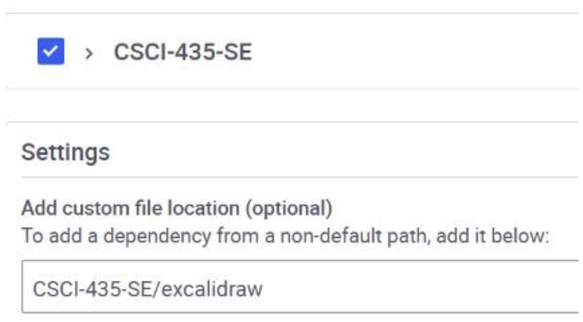
Snyk groups issues by the upgrade that fixes them. Each one shows its severity, a link to the advisory, and the dependency path.

02 In the Web App

Snyk's website, app.snyk.io presents the information in a much more readable format. To access your repo, begin by selecting "add project" in the projects tab.



Next, tick your organization and expand it to select your respective repo. Follow by clicking 'add selected repositories'. Snyk imports the repo and then automatically runs its first scan.



03 Automatic PR checks

Once your repo is imported, open Settings → Integrations → GitHub and turn on "Test new pull requests". Every PR then gets a security/snyk pass/fail check on GitHub.

Reading Results

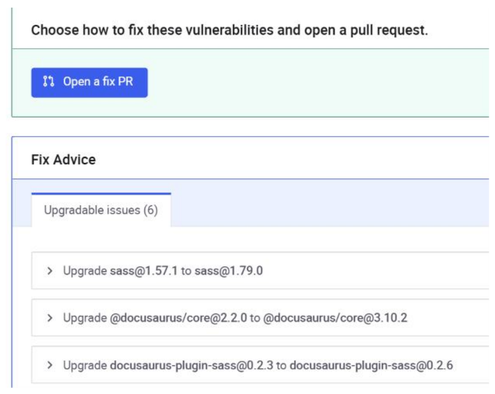
01 Open a project

In Snyk, the repo is a target and each package.json in it is its own project. On Projects, expand your respective repo and click your target package

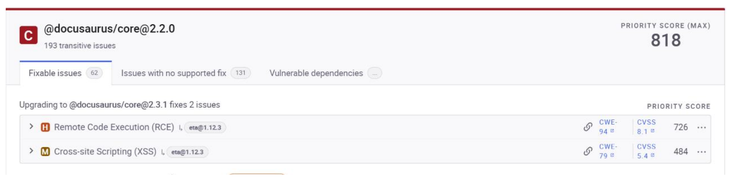


Issue counts are split by severity: Critical, High, Medium and Low. Sort by Issues to see the worst first, and triage properly.

02 Use Snyk's fixes

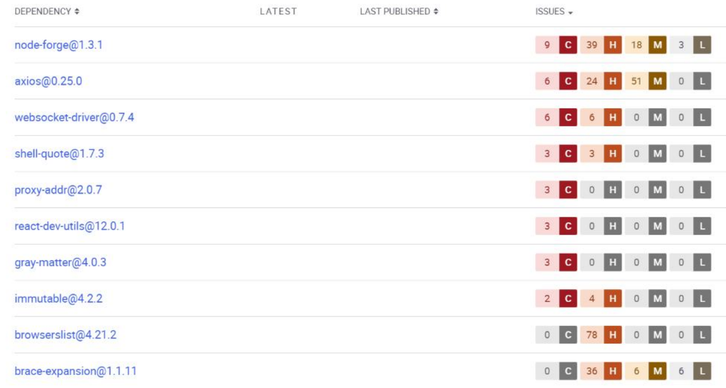


Fix Advice lists the upgrades that clear the most issues. Click Open a fix PR and Snyk opens a GitHub pull request with them.



Expand a package to see each issue it brings in, with its CWE, CVSS score and Snyk's priority score (out of 1000).

03 Inspect dependencies



The Dependencies page lists every package, including indirect ones, with its issue counts, so you can see which ones cause the most problems.

EXTRA RESOURCES

Youtube Showcase

▶https://youtu.be/CJyUU9gpClg